

SOC War Room — Threat-Hunt & Incident Report

Two engagements: Workflow-Orchestration RCE | SIEM Blindspot on a Domain Controller

ANALYST Eswar Mahalingam	ROLE Blue Team — SOC Threat Hunter	REPORT DATE 22 Sep 2026 (IST)	CLASSIFICATION TLP:AMBER — Internal SOC	FRAMEWORKS MITRE ATT&CK · Sigma · CISA KEV
-----------------------------	---------------------------------------	----------------------------------	--	---

Engagement 1 — Workflow-Orchestration RCE

DAY 1 · Orkes Conductor

INCIDENT CONTEXT (VERIFIED AGAINST PUBLIC THREAT INTEL)

CVE-2026-58138 — Orkes Conductor pre-authentication Remote Code Execution. **CVSS 9.8** Affected **3.21.21** → **3.30.1**; fixed in **3.30.2+**. Root cause: unsandboxed GraalVM script evaluators (`HostAccess.ALL` / `allowAllAccess(true)`) reachable through `INLINE`, `LAMBDA`, `DO_WHILE` and `SWITCH` task types. A crafted JS/Python expression inside a workflow definition invokes OS commands via Java reflection or subprocess — **without any authentication**. Actively exploited in the wild since ~24 Jul 2026 (thousands of attempts observed early Sept, source regions incl. India).

The patch is necessary but not sufficient. Patching stops *future* exploitation; it does not tell us whether the window 20 Jul → patch date was already used. Because Conductor is an *automation hub holding credentials to many systems*, the real question is not "is the server fixed" but "did anything execute, and what could it reach." That is why the answer to Management is **✗ Not yet**.

MISSION 01 — Asset Discovery

Scope the blast radius before hunting

What SOC must know	Why it matters / what "bad" looks like	Where to get it (data source)
Conductor version	Confirms whether the instance was ever in the 3.21.21–3.30.1 vulnerable range and for how long.	Deployment manifest / <code>/health</code> & <code>/api/metadata</code> , container image tag, Helm/Git history.
Internet & API exposure	Pre-auth RCE only bites if the workflow API was reachable. Public exposure = assume-breach posture.	External ASM/Shodan, cloud SG/NACL & LB rules, reverse-proxy config, WAF logs.
Authentication config	Was auth enforced in front of the API? Anonymous workflow submission is the exploit path.	Conductor security config, API gateway/OAuth settings, ingress annotations.
Workflow inventory + recent changes	A malicious workflow using <code>INLINE</code> / <code>LAMBDA</code> with shell-like expressions is the primary IoC.	<code>GET /api/metadata/workflow</code> , workflow-definition Git repo, Conductor audit/change log.
Connected systems & service accounts	Defines <i>what the attacker could reach</i> if code ran — DBs, queues, cloud APIs, internal apps.	Task-worker configs, integration/connector list, IAM role attached to the pods/host.
API tokens / cloud / DB creds	Machine identities the engine can read = the loot. Central to Mission 04.	Env vars, mounted secrets, K8s Secrets, Vault paths, cloud instance-profile.
Process execution on host/pod	RCE = a child process off the Java/Conductor parent (sh, curl, python, base64).	EDR/Sysmon (Event 1), <code>auditd execve</code> , container runtime logs, Falco.
Network connections	Post-exploit C2, tool pull, or data egress from an app tier that should be quiet.	Firewall/flow logs, EDR net telemetry, DNS logs, cloud VPC Flow Logs.

Asset-map takeaway: Conductor is a **Tier-0-adjacent** asset — treat any confirmed execution as potential access to every integrated system, not just the box.

MISSION 02 — Hunting Hypotheses

Structured, falsifiable, evidence-driven

Hypothesis	Evidence required	Data source	Expected indicators	False positives	Investigation conclusion (how to decide)
H1 — API targeted before remediation	Inbound requests to the workflow API during 20 Jul → patch, esp. POST of workflow defs from external IPs.	WAF / reverse-proxy / LB access logs, Conductor request logs.	POSTs to <code>/api/workflow</code> or metadata endpoints containing <code>INLINE</code> / <code>LAMBDA</code> / JS keywords; 4xx → 200 shift; odd geos/UA.	Legit DevOps automation, load-balancer health checks, internal CI creating workflows.	Confirmed if external IP submitted an inline-expression workflow that returned 200 and correlates with a child process (H-cross to Mission 03).
H2 — Malicious workflow / config change introduced	New or modified workflow definitions containing evaluator tasks with command-like expressions; auth/sandbox setting changes.	Conductor metadata + audit log, workflow-def Git history, config management.	<code>INLINE</code> task calling <code>java.lang.Runtime</code> , <code>ProcessBuilder</code> , <code>exec</code> , <code>curl bash</code> ; disabled sandbox; new task worker.	Legitimate new workflow release; a developer genuinely using <code>LAMBDA</code> for data transforms.	Confirmed if a workflow def contains OS-command reflection/subprocess and was created outside change control (no ticket, off-hours, unknown author).
H3 — Engine credentials accessed / abused	Reads of mounted secrets/env; anomalous use of Conductor's service account, API tokens or cloud role after suspected exec.	Cloud CloudTrail/Audit, IAM/STS logs, secret-store (Vault) access logs, DB auth logs.	Conductor role used from a new IP/UA; <code>sts:GetCallerIdentity</code> , mass secret reads, new access keys, DB logins at odd hours.	Normal task workers legitimately using the same role for their jobs.	Confirmed if the engine identity performed actions outside its normal task baseline (new principals, unusual API calls, egress) after the exec window.

Detection Name	Conductor Evaluator Spawns OS Process (Workflow-Engine RCE)
Telemetry	Endpoint/container process creation — Sysmon Event ID 1 / Linux <code>auditd execve</code> / EDR / Falco.
Relevant fields	<code>ParentImage</code> , <code>Image</code> , <code>CommandLine</code> , <code>ParentCommandLine</code> , <code>User</code> , container/pod ID.
Severity	Critical — pre-auth RCE on a credential-bearing asset.

T1190 Exploit Public-Facing App T1059 Command & Scripting T1552 Unsecured Credentials

```
# Sigma-like logic
detection:
  parent:
    ParentImage|endswith:
      - '/java' # Conductor JVM
    ParentCommandLine|contains: 'conductor'
  child:
    Image|endswith:
      - '/sh' - '/bash' - '/curl'
      - '/wget' - '/python*' - '/nc'
condition: parent and child
fields: host, ParentImage, Image, CommandLine
```

False positives	Analyst response (triage playbook)
Workflows that legitimately shell out (rare, should be inventoried & allow-listed by workflow name + host); container init scripts at pod start.	1) Pull full process tree + <code>CommandLine</code> . 2) Correlate to the workflow def & submitter IP (H1/H2). 3) If unauthorized: isolate pod/host, snapshot for forensics, hunt outbound (H3). 4) Escalate to IR & begin credential rotation (Mission 04).

Why this detection: the exploit is polymorphic at the payload layer, but almost every useful outcome ends in *the Java parent spawning a shell/network binary* — a behavioural chokepoint that survives payload obfuscation, unlike a signature on the request body.

Credential type	Rotate if compromise suspected?
Service accounts (engine + task workers)	YES — first · broad standing access
API tokens (integrations)	YES · directly readable from env/secrets
Cloud credentials / instance role	YES — priority · pivot to whole cloud account
Database credentials	YES · data access / exfil path
CI/CD credentials	YES · supply-chain blast radius
Webhook secrets	YES · lower priority, enables spoofed callbacks

DECISION & REASONING

Rotate everything the engine could read — in priority order: cloud/instance role → service accounts → DB → CI/CD → API tokens → webhook secrets.

Rationale: with unauthenticated code execution, any secret *reachable from the process* (env vars, mounted files, instance metadata) must be treated as **already disclosed** — you cannot prove a negative from logs alone. Cloud/instance credentials rank first because they enable the widest lateral movement and quiet persistence (new IAM users/keys). Rotation must be paired with **revoking existing sessions/tokens** (not just issuing new ones) and reviewing for attacker-created identities, or rotation is cosmetic.

- ☐ Vulnerable version identified (3.21.21–3.30.1)
- ☐ Fixed version verified (≥ 3.30.2)
- ☐ Internet / API exposure assessed
- ☐ Pre-patch API activity reviewed (H1)
- ☐ Workflow / config changes reviewed (H2)
- ☐ Service-account activity reviewed (H3)
- ☐ Credentials assessed & rotated (M04)
- ☐ Network / egress activity reviewed
- ☐ Persistence investigated (workers, cron, workflows)
- ☐ Evidence preserved (images, logs, defs)
- ☐ Monitoring increased (detection deployed)
- ☐ Business owner informed

Vulnerable server with no integrations vs. vulnerable automation platform holding privileged credentials?

The automation platform is far more dangerous. A standalone box is a single endpoint — compromise is bounded by that host. An orchestration engine is a **credential concentrator and a trust hub**: it legitimately holds service accounts, cloud roles and DB creds, and it is *expected* to talk to many systems. RCE there converts one bug into pre-authenticated lateral movement across everything it integrates with, and the malicious traffic blends into normal automation. Blast radius, not the CVSS number, is what decides severity.

INCIDENT CONTEXT

DC-02-PRD has sent **zero logs to Wazuh** for ~48h (last event 20 Sep 2026, 02:14 IST). In the same window: **4624** anonymous logon + **SeDebugPrivilege**, **1102** security audit log cleared, and **4688** `mimikatz.exe` renamed `svchost.exe`. Host is patched; AV says "No Threat Found"; IT wants to "reinstall the agent." **✗ Not yet** — a **Domain Controller going silent right after a log-clear and a cred-dump binary is not an agent bug; it is deliberate SIEM blinding to cover credential theft on Tier-0**. Silence here is itself the alert.

MISSION 01 — Asset Discovery

DC = Tier-0, treat accordingly

What SOC must know	Why	Data source
Role of DC-02-PRD (PDC/BDC/RODC)	Writable DC with KRBTGT/replication rights = worst case (Golden Ticket, DCSync).	AD Sites & Services, <code>netdom query fsmo</code> , RODC flag.
Exposure (internet vs internal)	DCs must be internal-only; any exposure widens entry paths.	Firewall rules, external ASM, VPN/segmentation config.
Wazuh agent status & version	Was the agent stopped, killed, or network-blocked? Distinguishes bug from tamper.	Wazuh manager (agent last-keepalive), service state via out-of-band mgmt.
Patch cycle + EDR status	"Patched + AV clean" with a renamed mimikatz = evasion, not safety.	WSUS/SCCM, EDR console health, defender exclusion list.
Domain Admin / DCSync rights holders	Baseline of who <i>should</i> have replication rights to spot additions.	AD group membership, ACLs on domain object (DS-Replication-Get-Changes).
Recent logon activity on DC	Interactive/remote logons to a DC are rare and high-signal.	4624/4625/4648, RDP (TerminalServices), Wazuh archive pre-02:14.
Service accts / recent GPO changes	Persistence via new service, logon script, or malicious GPO.	4720/4722/4728/5136/5141, SYSVOL diff, GPO version history.
NTLM/Kerberos auth around 20 Sep 02:14	Anchor timeline for cred access & lateral movement.	4768/4769/4776 on all DCs, network auth logs.
Network connections (last 7d)	Lateral movement to other DCs / exfil.	NetFlow, firewall, EDR net telemetry, other DCs' 4624 src=DC-02.

MISSION 02 — Hunting Hypotheses

Hypothesis	Evidence required	Data source	Expected indicators	False positives	Conclusion (how to decide)
H1 — Logs cleared to hide credential access	Log-clear event + preceding privileged logon / LSASS access.	Wazuh archives, Sysmon (10 = LSASS access), other DCs.	1102 (+System 104); 4624 anon + SeDebugPrivilege (4672); Sysmon 10 target <code>lsass.exe</code> .	Authorized admin clearing logs during maintenance (should have a ticket).	Confirmed: 1102 with no change ticket, preceded by SeDebug logon + LSASS access ⇒ credential dump cover-up.
H2 — Agent disabled to create SIEM blindness	Agent stop/kill or network block coinciding with the attack window.	Wazuh manager keepalive, Sysmon 1/5, Service Control (7034/7040).	Last keepalive == 02:14; <code>wazuh-agent</code> stopped; sc.exe/net stop; FW rule added.	Genuine agent crash, host reboot, network outage.	Confirmed: agent stopped by a process/user (not crash) at the same minute as H1 activity ⇒ deliberate blinding.
H3 — Persistence via new account / task / GPO	New privileged principals, scheduled tasks, services, or GPO/logon-script changes post-compromise.	4720/4728/4732; 4698 (task); 7045 (service); 5136/5141; SYSVOL.	New Domain Admin; scheduled task on DC; new service; DCSync ACL grant; shadow-cred (msDS-KeyCredentialLink).	Legit IT onboarding / approved automation change.	Confirmed: any new Tier-0 principal/task/ACL created off-hours with no change record ⇒ persistence.

MISSION 03 — Detection Engineering

Detect the blindness itself

Detection Name	Tier-0 Log-Source Silence + Audit-Clear Correlation
Telemetry	SIEM heartbeat/keepalive metadata + Windows Security (1102) + System (104, 7034/7040).
Relevant fields	agent.id, host.role, last_keepalive, EventID, SubjectUser, Channel.
Severity	Critical for DC/Tier-0; High for member servers.

T1562.001 Disable/Modify Tools T1070.001 Clear Windows Logs
T1003 OS Credential Dumping

```
# Sigma-like / correlation logic
rule A (absence):
  IF host.role == "domain_controller"
  AND now() - last_keepalive > 15m
  THEN raise "DC log source silent"

rule B (tamper): EventID in (1102, 104)

correlation: A within 24h of B
  or A within 24h of (4624 LogonType=3
    AND PrivilegeList contains SeDebugPrivilege)
  => escalate CRITICAL
```

False positives	Analyst response
Planned DC reboot/maintenance, agent upgrade, network maintenance — all should map to a change ticket and clear within the window.	1) Verify against change calendar. 2) Reach DC out-of-band (do NOT trust the host's own logs). 3) If no ticket + tamper events ⇒ treat as active intrusion, isolate, preserve, invoke IR & Mission 04.

Key idea: most SIEMs alert on *bad events*; mature SOCs also alert on the **absence of expected events**. A Tier-0 source going quiet must page, because attackers delete what they can't prevent from being written.

MISSION 04 — Identity & Persistence Hunt

- New Domain Admins — 4728/4732, compare to baseline
- DCSync / DS-Replication ACL grants — 4662 (GUID 1131f6aa/1131f6ad), 5136
- Shadow credentials — msDS-KeyCredentialLink changes (5136)
- Golden Ticket exposure — KRBTGT last-set date; anomalous long-life TGTS
- New service accounts — 4720/4722; Kerberoastable SPNs added
- Scheduled Tasks on DC — 4698 / schtasks, Sysmon 1
- New GPO / logon scripts — 5137/5136, SYSVOL diff

T1003.006 DCSync T1558.001 Golden Ticket T1098 Account Manipulation

THE ONE THING BEFORE BRINGING WAZUH BACK ONLINE

Isolate & forensically preserve DC-02-PRD first — take a memory + disk image (and quarantine the host from the network) BEFORE restarting the agent or touching the box.

Reinstalling/restarting the agent risks overwriting artefacts, alerting the attacker, or wiping volatile evidence (LSASS memory, injected processes, network state). Since logs were already cleared, the host's own logs can no longer be trusted — memory and disk forensics + other DCs' replication/auth logs become the source of truth. Only after evidence is captured and the DC is contained do you restore telemetry. (If broader domain compromise is confirmed, the enterprise-level action is a double KRBTGT reset — but preservation/containment comes first on this host.)

MISSION 05 — Incident Closure Checklist

- ☐ DC-02-PRD isolation verified
- ☐ Wazuh + Sysmon preserved (disk/mem image)
- ☐ 1102, 4624, 4672, 4720, 4728, 4768, 4776 reviewed
- ☐ Credential-dump (LSASS) activity investigated
- ☐ Domain Admin membership audited
- ☐ KRBTGT double-reset considered
- ☐ Service & Kerberoastable accounts reviewed
- ☐ Persistence (task/service/GPO) investigated
- ☐ Lateral movement to other DCs reviewed
- ☐ Evidence preserved for forensics
- ☐ DC monitoring increased / rules tuned
- ☐ AD / business owner informed

Senior SOC Question

A DC generating 10,000 alerts vs. a DC generating ZERO alerts for 48h — which is more dangerous?

Zero alerts is more dangerous. 10,000 alerts is noisy but observable — you still have telemetry and can tune, triage and correlate; it's a tuning problem. Zero alerts from a Tier-0 asset means you have lost visibility: either nothing is happening, or something is actively suppressing what you'd see — and you cannot tell which. From a detection-engineering view, absence of data is not evidence of safety; it removes your ability to detect at all. That's why silence on a DC must be modelled as a first-class, page-worthy detection, not dismissed as "the agent has a bug."

Submission Pack — Summary & ATT&CK Coverage

SUBMISSION

5-Line Analyst Summary

Both engagements

1. Investigated two SOC war-room scenarios end-to-end: an unauthenticated RCE on an Orkes Conductor workflow platform (CVE-2026-58138, CVSS 9.8) and a Domain Controller (DC-02-PRD) that went silent in Wazuh for 48h after a log-clear and a cred-dump binary.
2. For each I built an asset map, three falsifiable hunting hypotheses (with evidence, data source, indicators, false positives and a decision rule), one high-fidelity detection concept, a machine-identity / persistence analysis, and an evidence-based closure checklist.
3. Core Day-1 insight: patching stops future exploits but not past ones — an automation engine is a credential concentrator, so any confirmed execution means every integrated secret must be treated as disclosed and rotated (cloud role first).
4. Core Day-2 insight: mature SOCs alert on the absence of expected telemetry — a silent Tier-0 log source must page, and the first action is forensic preservation/containment before restarting the agent, because cleared logs mean the host can no longer be trusted.
5. Both answers to "can we close?" are Not yet — closure follows evidence and credential/persistence review, not the patch or the "AV clean" verdict.

MITRE ATT&CK Coverage Map

ID	Technique	Where used
T1190	Exploit Public-Facing App	Day 1 — API RCE entry
T1059	Command & Scripting Interpreter	Day 1 — evaluator exec
T1552	Unsecured Credentials	Day 1 — engine secrets
T1003 / .006	OS Cred Dumping / DCSync	Day 2 — LSASS, replication
T1070.001	Clear Windows Event Logs	Day 2 — Event 1102
T1562.001	Impair Defenses: Disable Tools	Day 2 — silent agent
T1558.001	Golden Ticket	Day 2 — KRBTGT check
T1098	Account Manipulation	Day 2 — persistence

Deliverables map to submission: Asset Map (M01) · Hunting Hypotheses (M02) · Detection Concept (M03) · Machine-Identity / Persistence (M04) · Closure Checklist (M05) — for both war rooms.

Sources / references: The Hacker News — Orkes Conductor CVE-2026-58138 pre-auth RCE (versions, mechanism, exploitation); FortiGuard Labs Outbreak Alert — Orkes Conductor Evaluator RCE; SecurityWeek — Critical Orkes Conductor vulnerability exploited. Frameworks: MITRE ATT&CK (attack.mitre.org), Sigma (sigmahq.io), Wazuh docs (documentation.wazuh.com), CISA KEV (cisa.gov). · Prepared by Eswar Mahalingam · GraySentinel DSOU · 22 Sep 2026 · TLP:AMBER.